Beyond user permissions, till root dance

It's time to transcend user permissions and "escalate".

Adhyayan Panwar | feedback@digit.in

As we clack away on our keyboards, running numerous scripts, sipping Club-Mate and green code flooding the screens, the "1337 h4x0r" vibes kick in. Breaking into firewalls after firewalls, we are finally at our destination, the esteemed terminal and we have donned the disguise of the user Alice. But, wait what? Alice can only play music files on this system!? This is not what we spend endless nights in underground leet hacker forums for. It's time to transcend user permissions and "escalate".

You must be thinking what are we blabbering about, so let us take you through the thinking process of a hacker when he decides to make a move. Imagine what was going through the mind of Vasily Kravets when he found a way to become administrator of any computer with Steam (yeah gamers, you guessed it right) installed because of a design flaw in the Steam client or how the most loved Chrome browser can be manipulated to compromise a system. Be it a software developed by a big corporation or getting in school systems to change grades (don't do this though), the overall process remains the same. In almost every system we have tackled, following the simple methodology of enumerate, exploit and escalate, which we like to call the 3E process, has always proved fruitful to us:

- Find as much information/intel about the system as you can.
- Figure out the weakest link and break in through that point.
- Escalate from a weak user (most exploitable services have only limited privileges) to a more powerful user.

The last step is where the privilege escalation attacks take place. According to Forrester, almost 80% of security breaches involved privilege escalation and privileged credentials abuse in one way or another. where a system misconfiguration or a design/implementation flaw unwittingly lets an attacker interact with the system as a user with more permissions than intended. Privilege escalation is done mostly after you have some sort of access to a system shell. These kinds of attacks are broadly of two types:

- Vertical privilege escalation
- Horizontal privilege escalation

Vertical Privilege Escalation:
When an attacker gains access to a user with more power than the current user, then the attacker has performed vertical privilege escalation. Say, you worked your head off all day installing Arch Linux in your new laptop and preferably, gave your account all the permissions. Then your best friend comes along and wants to use your laptop to read a book, so you created an account for him just giving him enough freedom to read files. But what do you see when you come back? Your friend has played a prank on you by running the dreaded sudo rm -rf because he was able to read the file you store your password in.

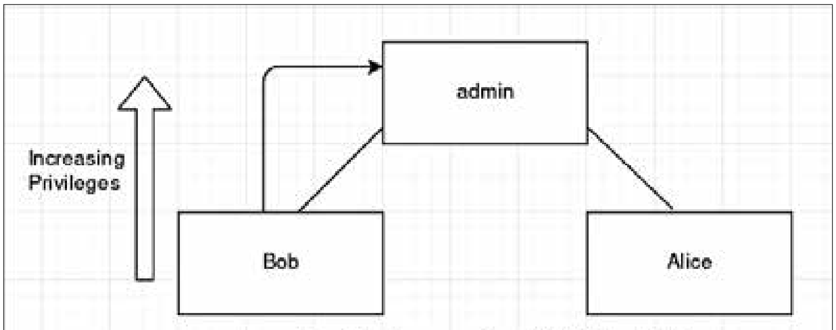

Fig. Attacker moves from "Bob" to "admin"

Horizontal Privilege Escalation:
In contrast to vertical privilege escalation, this type of attack takes place when an attacker goes from a user with certain permissions to another user having similar permissions. We all remember the good old days of Windows XP, where our parents had one "Administrator" account and separate accounts for you and your brother/sister. But your sibling is a closet hacker and got access to your account (this was actually possible back in the day: https://dgit.in/xphak).